

02-08

O texto reúne boas práticas de desenvolvimento seguro, mostrando que segurança não é uma etapa, mas um atributo presente em todas as fases do ciclo de vida. A ideia central é "shift-left": antecipar a segurança para o início do projeto, onde o custo de correção é mínimo.

Boas práticas por fase:

- Requisitos: identificar requisitos de segurança funcionais e classificar os dados (sensíveis & públicos);
- Design: aplicar threat modeling (ex.: STRIDE), revisar privilégios e defesa em profundidade;
- Codificação: validar entradas, usar PreparedStatement e ORM seguros, escapar saídas (XSS), evitar segredos no código e usar bibliotecas atualizadas;
- Testes: combinar SAST (estático), DAST (dinâmico), SCA (dependências) e pentest;
- Deploy e operação: configuração segura por padrão, HTTPS/TLS, monitoramento, logging sem dados sensíveis e gestão de patches.

Cultura e processos: Treinar desenvolvedores continuamente, integrar DevSecOps (camadas CI/CD) e usar frameworks de maturidade (SDL, SAMM, ASIMM, NIST SSDF).

Conclusão: ~~sem~~ software seguro nasce do processo + pessoas + ferramentas. Nenhuma ferramenta isolada protege uma equipe que não trata segurança como requisito de qualidade. Adotar essas práticas reduz risco, custo e exposição da organização.